

Normas

BANCO LUNA LLENA

Nombre del equipo: CACTUCITOS

Integrantes:

- Josue Nisthaus
- Carlos Caba
- Luciana Velasco
- Daniela Guzman
- Jose Manzaneda

LA PAZ, BOLIVIA - 2026

ADVERTENCIA

Este documento y su contenido se clasifica como **USO INTERNO**, contiene información propia del Banco Luna Llena, siendo de uso exclusivo del personal autorizado de la institución. No puede ser distribuida ni divulgada a personas ajenas a la misma sin autorización de la Máxima Autoridad Ejecutiva, en forma total o parcial; la reproducción o divulgación NO autorizada de este material estará sujeta a sanciones que correspondan de acuerdo con la legislación vigente y a las políticas y normas del Banco Luna Llena.

Versión: 3.0

Fecha: 13/04/2026

Aprobado por: Gerente General del Banco Luna Llena

Fecha de vigencia: 13/04/2026

Histórico de revisiones del Documento

Versión	Fecha	Detalle de Revisión y Cambios
1.0	11/03/2026	Creación del documento
2.0	14/04/2026	Modificación de formato
3.0	19/05/2026	Agregación y actualización de procedimientos

Índice

1. Introducción	5
2. Objetivo General	5
Objetivos Específicos	5
3. Alcance	6
4. Base Legal y Marcos de Referencia	6
4.1 Marcos Internacionales	6
4.2 Normativa Nacional	6
5. Glosario de Términos	7
6. Documentos Internos Relacionados	7
7. Documentos Externos Relacionados	7
8. Abreviaturas	8
9. Principios Generales de la Auditoría de Sistemas	8
10. Normas de Organización y Gobierno de la Auditoría	9
10.1 Independencia y Objetividad	9
10.2 Competencia Profesional	9
10.3 Autoridad y Responsabilidades	9
11. Normas de Planificación de la Auditoría	10
11.1 Evaluación de Riesgos	10
11.2 Plan Anual de Auditoría	10
11.3 Programa de Auditoría	12
12. Normas de Ejecución de la Auditoría	12
12.1 Recolección de Evidencia	12
12.2 Pruebas de Control	12
12.3 Documentación de Papeles de Trabajo	13
13. Normas de Comunicación y Reporte	13
14. Normas de Seguimiento	14
15. Normas por Dominio Tecnológico	14
15.1 Seguridad de la Información	14
15.2 Infraestructura y Redes	15
15.3 Desarrollo Seguro de Software	16
15.4 Continuidad del Negocio y Recuperación ante Desastres	16
15.5 Computación en la Nube	17
15.6 Gestión de Incidentes	18
16. Incumplimientos y Sanciones	18
17. Aprobación	19

1. Introducción

El Banco Luna Llena es una entidad financiera mediana con aproximadamente 500 empleados, ubicada en La Paz, zona Achumani. Ofrece servicios de captaciones, colocaciones, servicios digitales, transferencias electrónicas y productos financieros innovadores. El Área de Tecnologías de Información está conformada por 13 profesionales distribuidos en el nivel directivo (Gerente de TI y Gerente de Seguridad de la Información), tres subgerencias operativas (Desarrollo y Proyectos; Redes, Comunicaciones y Soporte; y Operaciones y Gestión de Datos) y el Área de Calidad.

El presente documento establece las Normas de Auditoría de Sistemas del Banco Luna Llena, instrumento normativo que regula el proceso de revisión independiente, sistemática y objetiva de los sistemas de información, la infraestructura tecnológica, los controles de seguridad y los procesos de TI de la institución. Estas normas son coherentes con los marcos estratégicos institucionales (PEI 2025–2030, PETI, PESI), las políticas de seguridad de la información y los estándares internacionales adoptados por el banco.

2. Objetivo General

Establecer las directrices y responsabilidades que rigen la auditoría de sistemas de información en el Banco Luna Llena, garantizando que los recursos tecnológicos, los controles de seguridad y los procesos de TI operen con integridad, confidencialidad y disponibilidad, alineados al Plan Estratégico Institucional 2025–2030 y a la normativa vigente.

Objetivos Específicos

- Verificar que los controles de seguridad implementados sean suficientes y efectivos, alineados a ISO/IEC 27001, PCI DSS v4.0 y la normativa ASFI.
- Evaluar el cumplimiento de las políticas, normas y procedimientos de TI definidos en el PESI, PETI y las Políticas de Seguridad de la Información del banco.
- Identificar vulnerabilidades y deficiencias en la infraestructura tecnológica, sistemas de información y procesos de desarrollo del banco.
- Emitir recomendaciones orientadas a la mejora continua del SGSI y los controles de TI de la institución.
- Verificar el cumplimiento de los objetivos de disponibilidad, RTO y RPO para los sistemas críticos del banco.

3. Alcance

Las presentes normas aplican a:

- Toda la infraestructura tecnológica del Banco Luna Llena: servidores, estaciones de trabajo, dispositivos de red, sistemas de almacenamiento y entornos cloud (AWS).
- Las aplicaciones empresariales: Core Bancario Cobis v7.2, CRM Salesforce, ERP SAP S/4HANA, plataforma de banca en línea y aplicación móvil.
- Los sistemas de seguridad: firewalls Fortinet, IDS/IPS Snort, SIEM IBM QRadar, solución EDR CrowdStrike y DLP Forcepoint.
- El personal del Área de TI (13 profesionales), la Alta Gerencia, las demás unidades organizacionales y proveedores de servicios con acceso a los sistemas del banco.
- Los procesos de desarrollo, operaciones, soporte, gestión de incidentes y continuidad del negocio.

4. Base Legal y Marcos de Referencia

4.1 Marcos Internacionales

Marco / Estándar	Aplicación en Banco Luna Llena
ISO/IEC 27001:2022	SGSI vigente; última auditoría marzo 2026. Base principal para controles de seguridad.
PCI DSS v4.0	Obligatorio por procesamiento de tarjetas de crédito y débito; revisión anual de controles.
NIST CSF 2.0	Guía la Gerencia de Seguridad en las funciones Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar.
CIS Controls v8	18 controles técnicos aplicados por la Subgerencia de Redes; línea base de seguridad en servidores, red y cloud.
COBIT 2019	Marco de gobierno y gestión de TI; referencia para la evaluación del Comité de TI y el PETI.
OWASP Top 10 (2021)	Controles de desarrollo seguro aplicados por la Subgerencia de Desarrollo y Proyectos.

4.2 Normativa Nacional

- Normativa ASFI – Autoridad de Supervisión del Sistema Financiero de Bolivia.
- Circular ASFI N° 088/2020 – Ciberseguridad para entidades financieras.
- Legislación boliviana vigente en materia de protección de datos y servicios financieros digitales.

5. Glosario de Términos

Los términos utilizados en el presente documento se encuentran en el Glosario de Términos y Definiciones del Banco Luna Llena.

6. Documentos Internos Relacionados

Descripción	Código
Plan Estratégico Institucional 2025–2030	PEI-001
Plan Estratégico de Seguridad de la Información 2025–2030	PESI-001
Plan Estratégico de Tecnología de la Información 2025–2030	PETI-001
Políticas de Seguridad de la Información	PSI-001
Estándares y Metodologías (Scrum, PCI DSS, NIST CSF, CIS Controls)	EST-TI-001
Organigrama Funcional del Área de Tecnologías de Información	ORG-TI-001
Inventario de Infraestructura de TI	INF-TI-001
Manuales de Funciones por Cargo (13 cargos)	MF-TI-001 al 013
Plan de Recuperación ante Desastres (DRP)	DRP-001
Reglamento Interno de Trabajo	RIT-001
Normas de Auditoría de Sistemas	NAS-001

7. Documentos Externos Relacionados

- Estándar ISO/IEC 27001:2022 – Sistema de Gestión de Seguridad de la Información.
- PCI DSS v4.0 – Payment Card Industry Data Security Standard.
- NIST CSF 2.0 – Marco de Ciberseguridad del Instituto Nacional de Estándares y Tecnología.
- CIS Controls v8 – Controles técnicos de ciberseguridad del Center for Internet Security.
- COBIT 2019 – Marco de gobierno y gestión de TI de ISACA.
- OWASP Top 10 (2021) – Riesgos críticos en aplicaciones web.

- Normativa ASFI – Autoridad de Supervisión del Sistema Financiero de Bolivia.
Circular ASFI N° 088/2020 (Ciberseguridad).

8. Abreviaturas

ASFI – Autoridad de Supervisión del Sistema Financiero de Bolivia.

BCP – Plan de Continuidad del Negocio (Business Continuity Plan).

DRP – Plan de Recuperación ante Desastres (Disaster Recovery Plan).

GSI – Gerencia de Seguridad de la Información del Banco Luna Llena.

GTI – Gerencia de Tecnologías de la Información del Banco Luna Llena.

MAE – Máxima Autoridad Ejecutiva: Gerente General del Banco Luna Llena.

MFA – Autenticación Multifactor (Multi-Factor Authentication).

PEI – Plan Estratégico Institucional.

PESI – Plan Estratégico de Seguridad de la Información.

PETI – Plan Estratégico de Tecnología de la Información.

RPO – Recovery Point Objective: punto máximo tolerable de pérdida de datos.

RTO – Recovery Time Objective: tiempo máximo tolerable para restaurar un sistema tras un incidente.

SGSI – Sistema de Gestión de Seguridad de la Información, implementado conforme a ISO/IEC 27001.

SIEM – Security Information and Event Management: plataforma de gestión de eventos e información de seguridad.

9. Principios Generales de la Auditoría de Sistemas

La auditoría de sistemas del Banco Luna Llena se rige por los siguientes principios:

- Independencia: El auditor no debe tener conflictos de interés con las áreas auditadas y actuará con plena autonomía de juicio.
- Objetividad: Los hallazgos y conclusiones se basarán exclusivamente en evidencia verificable, sin prejuicios ni influencias externas.
- Integridad: Se actuará con honestidad y ética profesional en todas las etapas del proceso de auditoría, en concordancia con los valores institucionales del banco.

- **Confidencialidad:** Toda la información obtenida durante la auditoría será tratada como confidencial y de uso interno, conforme a la política de clasificación de la información (categorías: Confidencial, Uso Interno, Uso General).
- **Competencia:** El auditor deberá poseer los conocimientos, habilidades y experiencia necesarios para ejecutar la auditoría con calidad profesional.
- **Basado en Riesgos:** La planificación y ejecución de la auditoría priorizarán los procesos y activos con mayor criticidad e impacto potencial para el banco.
- **Mejora Continua:** Los resultados de la auditoría contribuirán a la mejora del SGSI, del PETI y de los controles institucionales.

10. Normas de Organización y Gobierno de la Auditoría

10.1 Independencia y Objetividad

N-ORG-01: El auditor de sistemas no puede auditar procesos, sistemas o controles sobre los cuales haya tenido responsabilidad directa en el período auditado.

N-ORG-02: Cuando la auditoría sea ejecutada por personal interno del banco, el Gerente General garantizará la independencia funcional del equipo auditor respecto a la Gerencia de TI y la Gerencia de Seguridad de la Información.

N-ORG-03: Para auditorías de alto impacto (ISO 27001, PCI DSS, ASFI), el banco podrá contratar firmas externas especializadas, previa aprobación de la MAE.

10.2 Competencia Profesional

N-ORG-04: El equipo auditor deberá acreditar conocimientos en al menos uno de los marcos adoptados por el banco: ISO 27001, PCI DSS v4.0, NIST CSF 2.0, CIS Controls v8 o COBIT 2019.

N-ORG-05: El personal auditor participará en el programa de capacitación continua institucional (OE5 del PEI), con un mínimo de 40 horas de formación anual en temas de auditoría, ciberseguridad y tecnología financiera.

10.3 Autoridad y Responsabilidades

Rol	Responsabilidades en la Auditoría
Gerente General (MAE)	Aprobar el Plan Anual de Auditoría. Recibir el informe final. Autorizar auditorías especiales no planificadas.

Gerente de Seguridad de la Información (GSI)	Coordinar las auditorías del SGSI. Gestionar el seguimiento de hallazgos críticos (P1). Reportar incumplimientos al regulador ASFI.
Gerente de TI	Facilitar el acceso a sistemas e infraestructura durante la auditoría. Implementar las recomendaciones de mejora.
Subgerentes de Área	Proveer documentación y evidencia solicitada por el auditor. Participar en reuniones de apertura y cierre.
Analista de Calidad	Verificar el cumplimiento de estándares de seguridad en desarrollos. Apoyar la recolección de evidencia en auditorías de software.
Equipo Auditor	Ejecutar el programa de auditoría. Documentar hallazgos con evidencia. Emitir el informe de auditoría.

11. Normas de Planificación de la Auditoría

11.1 Evaluación de Riesgos

N-PLAN-01: Previo a la elaboración del Plan Anual de Auditoría, el equipo auditor realizará una evaluación de riesgos de TI considerando: criticidad de los activos de información (Core Bancario Cobis, bases de datos Oracle, plataforma de banca digital), resultados de auditorías anteriores, incidentes de seguridad registrados en el SIEM IBM QRadar, y el contexto del análisis FODA del PEI 2025–2030.

N-PLAN-02: La evaluación de riesgos se actualizará anualmente y ante eventos significativos (incidentes P1, cambios regulatorios, incorporación de nuevos sistemas o proveedores cloud).

11.2 Plan Anual de Auditoría

N-PLAN-03: El equipo auditor elaborará un Plan Anual de Auditoría de Sistemas que será aprobado por la MAE antes del 31 de enero de cada año. El plan incluirá como mínimo:

- Objetivos y alcance de cada auditoría programada.
- Dominios tecnológicos a auditar según el universo de auditoría (sección 13).
- Cronograma de ejecución con fechas tentativas de inicio y fin.
- Recursos humanos asignados y estimación de horas.
- Criterios de auditoría (marcos y normas aplicables por dominio).

N-PLAN-04: El Plan Anual contemplará como mínimo las siguientes auditorías obligatorias:

Auditoría	Frecuencia	Marco de Referencia	Responsable
Auditoría del SGSI (ISO 27001)	Anual	ISO 27001:2022	GSI / Externo
Revisión de controles PCI DSS	Anual	PCI DSS v4.0	GSI
Auditoría de infraestructura y redes	Semestral	CIS Controls v8	Subger. Redes
Auditoría de desarrollo seguro	Por proyecto / Sprint	OWASP Top 10 / Scrum	Analista Calidad
Prueba de DRP / Failover	Semestral	PSI 7.8 / DRP-001	GSI + Subger. Ops.
Prueba de penetración	Trimestral	NIST CSF 2.0	GSI / Empresa externa
Auditoría de accesos y privilegios	Semestral	PSI 7.4 / CIS Controls	GSI

N-PLAN-05: El Plan Anual incluirá un cronograma expresado en meses que detalle para cada auditoría: dominio auditado, período de ejecución, marcos de referencia aplicables, equipo asignado y horas estimadas. A continuación se presenta el formato mínimo del cronograma:

Auditoría	Trim. 1	Trim. 2	Trim. 3	Trim. 4	Marco
SGSI (ISO 27001)	X				ISO 27001:2022
PCI DSS		X			PCI DSS v4.0
Infraestructura y redes	X		X		CIS Controls v8
Prueba de penetración	X	X	X	X	NIST CSF 2.0
Accesos y privilegios		X		X	PSI 7.4
DRP / Failover		X		X	PSI 7.8 / DRP-001

11.3 Programa de Auditoría

N-PLAN-06: Para cada auditoría se elaborará un Programa de Auditoría específico que detalle los procedimientos, técnicas, herramientas y responsables de cada actividad. El programa deberá ser aprobado por el responsable de la auditoría antes del inicio de la fase de ejecución.

12. Normas de Ejecución de la Auditoría

12.1 Recolección de Evidencia

N-EJEC-01: El auditor recolectará evidencia suficiente, relevante y confiable para sustentar cada hallazgo. Las técnicas de recolección incluyen: entrevistas al personal del Área de TI, revisión documental (políticas, manuales, registros de Jira Service Management), inspección física del centro de cómputo (Sede Central, Achumani), análisis de logs del SIEM IBM QRadar, escaneos de vulnerabilidades con Tenable Nessus Pro y pruebas técnicas sobre los sistemas.

N-EJEC-02: El auditor respetará el principio de mínimo privilegio al acceder a sistemas e información institucional. Todo acceso especial otorgado durante la auditoría será registrado y revocado al finalizar la misma, conforme a la Política 7.4 de Administración de Usuarios y Accesos.

12.2 Pruebas de Control

N-EJEC-03: Las pruebas de control verificarán el funcionamiento efectivo de los controles implementados en los dominios tecnológicos del banco, incluyendo: reglas activas del IDS/IPS Snort (1.200 reglas), configuración de firewalls Fortinet FortiGate 600E, efectividad del SIEM IBM QRadar (85 reglas de correlación, 12 fuentes de log), segmentación de VLANs (VLAN 10 cajeros, VLAN 20 banca digital, VLAN 30 administrativa) y controles Zero Trust de Cisco ISE.

N-EJEC-04: El auditor verificará el cumplimiento de los umbrales de disponibilidad definidos en las Políticas de SI: Core Bancario Cobis $\geq 99.9\%$, aplicación móvil y banca web dentro de los SLAs establecidos.

12.3 Documentación de Papeles de Trabajo

N-EJEC-05: Todos los papeles de trabajo serán documentados de forma clara, completa y organizada, de manera que permitan a un auditor independiente reproducir los procedimientos y verificar las conclusiones. Incluirán como mínimo: objetivo del procedimiento, criterio de auditoría aplicado, evidencia obtenida, resultado y referencia al hallazgo.

N-EJEC-06: Los papeles de trabajo y evidencias se clasificarán como Confidencial y serán resguardados conforme a la Política 7.3 (Seguridad de la Información Física y Lógica), con acceso restringido al equipo auditor y la MAE.

13. Normas de Comunicación y Reporte

N-COM-01: Al inicio de cada auditoría se realizará una reunión de apertura con el Gerente de TI, el Gerente de Seguridad y los Subgerentes involucrados para presentar el alcance, los objetivos y el cronograma de la auditoría.

N-COM-02: Al concluir la fase de ejecución, el equipo auditor presentará los hallazgos preliminares al Gerente de TI y al Gerente de Seguridad en una reunión de cierre, previo a la emisión del informe final, a fin de verificar la exactitud de los hallazgos y recibir los descargos correspondientes.

N-COM-03: El informe final de auditoría se emitirá en un plazo máximo de 15 días hábiles tras la reunión de cierre y contendrá como mínimo:

- Resumen ejecutivo con principales hallazgos y conclusión global.
- Alcance y objetivos de la auditoría.
- Metodología y marcos de referencia utilizados.
- Hallazgos detallados: descripción, criterio, condición, causa, efecto y recomendación.
- Plan de acción propuesto con responsables y fechas comprometidas.
- Calificación del riesgo de cada hallazgo (P1–P4, conforme a la clasificación institucional de incidentes).

N-COM-04: Los hallazgos clasificados como P1 (críticos) serán comunicados de inmediato al Gerente General y al Gerente de Seguridad, sin esperar el informe final. Si corresponde, la GSI notificará al regulador ASFI conforme a la Política 7.7.

14. Normas de Seguimiento

N-SEG-01: El equipo auditor realizará el seguimiento de todas las recomendaciones emitidas en el informe final, verificando la implementación de los planes de acción acordados en los plazos comprometidos.

N-SEG-02: La GSI mantendrá un registro actualizado del estado de los hallazgos y sus planes de acción, disponible para la MAE y el regulador.

N-SEG-03: Los hallazgos no subsanados en los plazos acordados serán escalados a la MAE y podrán derivar en sanciones conforme al Reglamento Interno de Trabajo.

N-SEG-04: Las lecciones aprendidas de cada ciclo de auditoría se incorporarán a la mejora continua del SGSI, el PETI y el Plan Anual de Auditoría del siguiente período.

N-SEG-05: La GSI mantendrá una Matriz de Hallazgos institucional actualizada con todos los hallazgos emitidos en los informes de auditoría, con el siguiente formato mínimo:

ID	Hallazgo (descripción breve)	Responsable	Fecha compromiso	Estado	Fecha cierre
H-001	[Descripción del hallazgo]	[Cargo]	DD/MM/AAA A	Pendiente / En proceso / Cerrado	DD/MM/AAA A
H-002					

N-SEG-06: La Matriz de Hallazgos se revisará mensualmente por la GSI y se presentará trimestralmente al Comité de TI. Los hallazgos clasificados P1 que superen el plazo comprometido sin cierre serán escalados de inmediato al Gerente General y comunicados a ASFI si corresponde.

15. Normas por Dominio Tecnológico

15.1 Seguridad de la Información

Código	Norma	Responsable	Frecuencia	Marco
NAS-SI-01	Verificar la vigencia y cumplimiento de la certificación ISO/IEC 27001:2022, incluyendo la revisión de los controles del Anexo A aplicables al banco.	GSI	Anual	ISO 27001

NAS-SI-02	Auditar la efectividad del SIEM IBM QRadar: revisar las 85 reglas de correlación, las 12 fuentes de log activas y los alertas generados en el período.	GSI	Semestral	NIST CSF
NAS-SI-03	Verificar que el MFA esté habilitado para todos los accesos a sistemas críticos (Core Bancario, bases de datos Oracle, entornos cloud AWS).	GSI	Semestral	PSI 7.4
NAS-SI-04	Revisar la política de contraseñas: complejidad, periodicidad de cambio y ausencia de contraseñas compartidas.	GSI	Semestral	CIS Controls
NAS-SI-05	Evaluar los resultados de los escaneos de vulnerabilidades de Tenable Nessus Pro y verificar que las vulnerabilidades críticas hayan sido remediadas.	Subger. Redes	Trimestral	PCI DSS

15.2 Infraestructura y Redes

Código	Norma	Responsable	Frecuencia	Marco
NAS-INF-01	Verificar la correcta segmentación de VLANs (VLAN 10 cajeros ATM, VLAN 20 banca móvil/web, VLAN 30 administrativa) y la aplicación de la arquitectura Zero Trust mediante Cisco ISE.	Subger. Redes	Semestral	CIS Controls
NAS-INF-02	Auditar la configuración del par de firewalls Fortinet FortiGate 600E en modo activo-pasivo HA: reglas de acceso, zonas de seguridad y registros de eventos.	Subger. Redes	Semestral	NIST CSF
NAS-INF-03	Revisar el inventario actualizado de activos de red: 6 servidores Dell PowerEdge R750, 2 HP ProLiant DL380, 2 Cisco Catalyst 9500 (core), 12 Cisco Catalyst 9300 (distribución) y 80 APs Cisco 9120AX.	Adm. Servidores	Anual	CIS Controls

NAS-IN F-04	Verificar el cumplimiento del SLA de disponibilidad de red: ancho de banda contratado 1 Gbps + 500 Mbps redundante; consumo promedio y picos documentados por PRTG.	Subger. Redes	Mensual	PSI 7.8
NAS-IN F-05	Auditar la configuración de la VPN SSL Cisco AnyConnect para los 200 teletrabajadores: autenticación, cifrado y registros de acceso.	Subger. Redes	Semestral	ISO 27001

15.3 Desarrollo Seguro de Software

Código	Norma	Responsable	Frecuencia	Marco
NAS-DE V-01	Verificar que cada sprint de la Subgerencia de Desarrollo incluya revisiones de seguridad formales y que el Analista de Calidad valide el cumplimiento del OWASP Top 10 antes de aceptar el entregable.	Analista Calidad	Por sprint	OWASP / Scrum
NAS-DE V-02	Auditar que toda aplicación (plataforma banca en línea Spring Boot 3 + Angular 17, app móvil) pase pruebas de seguridad y revisión de código antes de su pase a producción.	Analista Calidad	Por release	PSI 7.9
NAS-DE V-03	Verificar la gestión de dependencias y componentes de terceros: actualización de librerías, análisis de vulnerabilidades conocidas (CVE) en el stack tecnológico.	Analistas Progr.	Trimestral	OWASP
NAS-DE V-04	Revisar los controles de acceso al repositorio de código fuente: autenticación, permisos y trazabilidad de cambios.	Subger. Desarrollo	Semestral	CIS Controls

15.4 Continuidad del Negocio y Recuperación ante Desastres

Código	Norma	Responsable	Frecuencia	Marco
--------	-------	-------------	------------	-------

NAS-DR P-01	Verificar que el RTO $\leq$ 4 horas y el RPO $\leq$ 2 horas se cumplan en las pruebas periódicas de Disaster Recovery. Última prueba exitosa: enero 2026 (3.2 horas).	GSI + Subger. Ops.	Semestral	PSI 7.8
NAS-DR P-02	Auditar la integridad y periodicidad de los backups: incrementales cada 6 horas hacia AWS S3 (São Paulo) con retención de 90 días; backups del NAS Synology RS3621xs+ (48 TB, RAID 6).	Adm. BD	Mensual	ISO 27001
NAS-DR P-03	Verificar la capacidad y disponibilidad del sitio de contingencia en CPS Data Center (Zona Sur, La Paz): capacidad del 60% de producción y tiempo de activación documentado.	Subger. Ops.	Semestral	PSI 7.8
NAS-DR P-04	Revisar los registros de disponibilidad del Core Bancario Cobis (meta $\geq$ 99.9%) y los tiempos de respuesta de transacciones (SLA: 500 ms al P95), monitoreados con Zabbix 6.4 y PagerDuty.	Analista Ops.	Mensual	PSI 7.8

15.5 Computación en la Nube

Código	Norma	Responsable	Frecuencia	Marco
NAS-CL D-01	Auditar la seguridad de las 3 instancias EC2 m5.4xlarge en AWS São Paulo: configuración de grupos de seguridad, cifrado de datos en reposo y en tránsito, y controles de acceso IAM.	Adm. Servidores	Semestral	ISO 27001/27018
NAS-CL D-02	Verificar que los contratos con AWS incluyan los criterios mínimos de la Política 7.5: tratamiento de datos personales, aceptación de evaluaciones periódicas, reporte de brechas y cumplimiento de la legislación boliviana.	GSI	Anual	PSI 7.5 / ASFI

NAS-CL D-03	Revisar los registros de acceso y actividad en el entorno cloud (AWS CloudTrail o equivalente) para detectar accesos no autorizados o anomalías.	GSI	Trimestral	NIST CSF
----------------	--	-----	------------	----------

15.6 Gestión de Incidentes

Código	Norma	Responsable	Frecuencia	Marco
NAS-IN C-01	Verificar que los incidentes P1 sean atendidos en menos de 15 minutos conforme a la clasificación institucional. Revisar los registros de Jira Service Management (promedio 42 incidentes/mes).	GSI	Mensual	PSI 7.7
NAS-IN C-02	Auditar la realización de simulacros de ciberataque trimestrales coordinados con empresa externa, verificando que los resultados generen lecciones aprendidas documentadas.	GSI	Trimestral	NIST CSF
NAS-IN C-03	Revisar que los incidentes críticos sean escalados a la Gerencia General y comunicados al regulador ASFI cuando corresponda, conforme a la Política 7.7.	GSI	Tras c/incidente P1	PSI 7.7 / ASFI
NAS-IN C-04	Verificar que las lecciones aprendidas de incidentes anteriores hayan sido incorporadas a la mejora de los controles del SGSI y al programa de simulacros.	GSI	Semestral	ISO 27001

16. Incumplimientos y Sanciones

El incumplimiento de las presentes Normas de Auditoría de Sistemas será sancionado conforme a los siguientes criterios:

Nivel de Incumplimiento	Descripción	Consecuencia	Escalamiento
Crítico (P1)	Obstaculización deliberada de la auditoría; falsificación de evidencia; incumplimiento de controles críticos de seguridad.	Sanción disciplinaria grave conforme al RIT-001. Comunicación a ASFI si corresponde.	MAE + GSI + ASFI
Alto (P2)	No implementación de recomendaciones P1 en los plazos comprometidos; acceso no autorizado a sistemas durante la auditoría.	Sanción disciplinaria moderada. Plan de acción inmediato.	MAE + GSI
Medio (P3)	Incumplimiento de plazos de entrega de documentación; desatención a recomendaciones de mejora.	Llamada de atención formal. Seguimiento reforzado.	Gerente de TI
Bajo (P4)	Incumplimientos formales menores sin impacto significativo en la seguridad.	Observación documentada en el próximo informe.	Subgerente de Área

Toda sanción se aplicará conforme al Reglamento Interno de Trabajo (RIT-001) y la legislación boliviana vigente.

17. Aprobación

El presente documento ha sido elaborado por el equipo CACTUCITOS en el marco de la materia de Auditoría de Sistemas y ha sido revisado para su coherencia con la documentación institucional del Banco Luna Llena.

Para su entrada en vigor, el documento deberá ser formalmente aprobado por las instancias correspondientes del Banco Luna Llena, momento a partir del cual quedará disponible para todo el personal dependiente de la institución, con clasificación de Uso Interno.

Elaborado por

Aprobado por

Equipo CACTUCITOS Auditoría de Sistemas – 2026	Gerente General Banco Luna Llena
Fecha: 13/04/2026	Fecha: ____/____/____